

Active Directory

General Theory Notes

25 Chapters – Complete AD Theory Reference

1. Introduction to AD 2. Architecture 3. Domain Controllers 4. DNS
 5. Kerberos 6. NTLM 7. LDAP 8. Organisational Units
 9. Users and Accounts 10. Groups and Permissions 11. Group Policy
 12. AD Replication 13. Sites and Site Links 14. FSMO Roles
 15. Trusts 16. AD Schema 17. Global Catalog 18. PKI and Certificates
 19. AD CS 20. Security Hardening 21. Auditing and Event IDs
 22. Attack Techniques 23. PowerShell for AD 24. Troubleshooting 25. Hybrid Identity
-

Chapter 1 – Introduction to Active Directory

1.1 Definition

Active Directory (AD) is a directory service by Microsoft, first released with Windows Server 2000. It provides centralised authentication, authorisation, and management for users, computers, and resources.

In simple terms: ONE place to store who everyone is, what they can access, and what rules apply to them.

1.2 The Problem Before AD

- Each PC manages its own local user accounts – adding a new employee means creating accounts on every machine
- Password changes must be done machine by machine
- No central way to enforce security policies (screen lock, password complexity)
- IT has no central inventory of what computers exist or who uses them

1.3 What AD Solves

- Single Sign-On: log in once, access everything you are authorised to use
- Centralised identity: create a user once, works on every domain machine
- Centralised policy: one GPO enforces settings across thousands of machines
- Centralised access control: one group grants or removes access to any resource

1.4 Where AD Fits in the Microsoft Stack

- On-premises: Active Directory Domain Services (AD DS) – runs on Windows Server, uses Kerberos and LDAP
- Cloud: Microsoft Entra ID (formerly Azure AD) – cloud-native, uses OAuth 2.0 and OIDC, NOT Kerberos
- Hybrid: Both together, synchronised via Microsoft Entra Connect

* Entra ID is NOT AD DS in the cloud. They use completely different protocols and have different features.

Chapter 2 – Active Directory Architecture

2.1 Logical Structure (largest to smallest)

Forest --> Tree --> Domain --> Organisational Unit --> Object

2.2 Forest

The FOREST is the top-level security boundary. Contains one or more domain trees sharing a common schema, global catalog, and two-way transitive trusts. The first domain is the forest root – cannot be changed.

* Most organisations have a single forest. Multiple forests are used after mergers or for specific security isolation.

2.3 Domain

Administrative and replication boundary. All DCs in a domain share the same AD database. Has a unique DNS name, its own security policies, and domain-wide FSMO roles.

2.4 Tree

A collection of domains sharing a contiguous DNS namespace. Example: contoso.com --> europe.contoso.com --> uk.europe.contoso.com. All automatically have two-way transitive trusts.

2.5 Organisational Units (OUs)

Containers within a domain used to: organise objects logically, delegate admin control, and scope Group Policy.

! OUs are NOT security boundaries. Domains are the security boundary. Users in one OU CAN access resources in another OU.

2.6 Object Types

- User - person account with username, password hash, attributes
- Computer - domain-joined machine account (ends with \$)
- Group - collection of users/computers for access control or email
- GPO - set of settings to apply to users/computers
- Contact - external person, email only, no login

Chapter 3 – Domain Controllers

3.1 What is a Domain Controller?

A Windows Server with AD DS role installed and promoted. Stores a copy of the AD database and handles: authentication, authorisation, replication, DNS, Group Policy delivery, and SYSVOL hosting.

3.2 The AD Database – NTDS.dit

Stored at C:\Windows\NTDS\ntds.dit. Contains ALL objects and attributes including password hashes. Uses Extensible Storage Engine (ESE). Replicated between all DCs.

! Never copy NTDS.dit while DC is running. Use System State Backup or VSS-aware tools.

3.3 Read-Only Domain Controllers (RODC)

- READ-ONLY copy of the AD database - used in branch offices with poor physical security
- Only caches specific credentials defined by Password Replication Policy
- If stolen, attacker can only compromise accounts cached on that RODC
- Changes replicate TO the RODC only - it cannot write to AD

3.4 DC Promotion Options

- New forest: creates brand new forest and first domain
- New domain in existing forest: adds a child domain
- Additional DC: redundant DC in an existing domain

* Always have at least TWO DCs per domain. Single DC = single point of failure for authentication.

3.5 DC Requirements

- STATIC IP address - never DHCP for a DC
- Before promotion: DNS points to existing DC to find the domain
- After promotion: DNS points to itself (127.0.0.1) as it IS the DNS server
- Time synchronised within 5 minutes of other DCs (Kerberos requirement)

Chapter 4 – DNS and Name Resolution

4.1 Why DNS is Critical for AD

AD relies entirely on DNS for service location. Clients ask DNS: "where is a DC I can authenticate with?" Without DNS, logins fail, GPO fails, replication fails.

! If DNS is broken, EVERYTHING in AD breaks. Always check DNS first when troubleshooting.

4.2 SRV Records – How Clients Find DCs

When a DC is promoted it automatically registers SRV records:

- `_ldap._tcp.domain.com` SRV port 389 --> DC01
- `_kerberos._tcp.domain.com` SRV port 88 --> DC01
- `_kpasswd._tcp.domain.com` SRV port 464 --> DC01
- `_gc._tcp.domain.com` SRV port 3268 --> DC01 (Global Catalog)

4.3 AD-Integrated DNS Zones

Zone data stored IN the AD database (NTDS.dit). Automatically replicates between all DCs. Supports secure dynamic updates. No manual zone transfers needed.

*** Always use AD-integrated zones in a domain. File-based zones are for standalone DNS servers only.**

4.4 DNS Record Types

- A: hostname --> IPv4 address
- AAAA: hostname --> IPv6 address
- CNAME: alias pointing to another hostname
- MX: mail exchanger
- NS: nameserver – authoritative for this zone
- SOA: Start of Authority – zone metadata, serial number, refresh intervals
- SRV: service location – `_service._proto.name` TTL class SRV priority weight port target
- PTR: reverse lookup – IP to hostname (in reverse lookup zones)

4.5 DNS Troubleshooting Commands

`nslookup domain.com` basic resolution check

`nslookup -type=srv _ldap._tcp.domain.com` SRV records check

`dcdiag /test:dns` full DNS health check

`ipconfig /flushdns` clear local DNS cache

`ipconfig /registerdns` re-register in DNS

Chapter 5 – Kerberos Authentication

5.1 What is Kerberos?

Ticket-based authentication protocol developed at MIT. Default AD authentication since Windows 2000. Never sends passwords over the network – uses encrypted tickets instead.

5.2 Key Principles

- Mutual authentication: both client and server verify each other
- No password transmitted: only encrypted proofs go over the network
- Time-limited tickets: TGT valid 10 hours by default
- Single Sign-On: one TGT used for all resource access in a session

5.3 Key Components

KDC (Key Distribution Center)

Runs on every DC. Two logical parts: AS (Authentication Service) issues TGTs. TGS (Ticket Granting Service) issues service tickets.

TGT – Ticket Granting Ticket

Master ticket issued after login. Encrypted with KRBTGT account hash. Client cannot read it but presents it to get service tickets. Valid 10 hours.

Service Ticket (ST)

Ticket for a specific service. Encrypted with the SERVICE ACCOUNT hash. Presented directly to the target service.

KRBTGT Account

Special account whose hash encrypts ALL TGTs. Compromise of this hash = Golden Ticket attack = complete domain compromise. Rotate after any breach (twice).

5.4 Complete Authentication Flow

Step 1 – AS-REQ

Client sends username + timestamp encrypted with password hash. Proves knowledge of password without sending it.

Step 2 – AS-REP

KDC decrypts timestamp. If valid and within 5 minutes: issues TGT encrypted with KRBTGT hash + session key.

Step 3 – TGS-REQ

Client wants to access a resource. Presents TGT + authenticator (timestamp + session key) + name of target service.

Step 4 – TGS-REP

KDC validates TGT and authenticator. Issues service ticket encrypted with TARGET SERVICE account hash.

Step 5 – AP-REQ

Client sends service ticket + new authenticator directly to target service.

Step 6 – Access Granted

Service decrypts ticket with its own hash. Validates authenticator. Grants access. KDC not involved again.

5.5 The 5-Minute Clock Skew Rule

Kerberos timestamps prevent replay attacks. If clocks differ by more than 5 minutes, authentication fails with

KRB_AP_ERR_SKEW. Clock hierarchy: NTP --> PDC Emulator --> other DCs --> domain members.

Check: w32tm /query /status Fix: w32tm /resync /force

5.6 Service Principal Names (SPNs)

Unique identifier for a service instance. Format: ServiceClass/Host:Port/ServiceName

Example: MSSQLSvc/sqlserver.contoso.com:1433

setspn -L accountname list SPNs on an account

setspn -S SPN account add an SPN

* Duplicate SPNs cause Kerberos failures. Run: setspn -X to find duplicates in the domain.

Chapter 6 – NTLM Authentication

6.1 What is NTLM?

Older Microsoft authentication protocol using challenge-response mechanism. Still present for backward compatibility but should be minimised in modern environments.

6.2 When NTLM is Used Instead of Kerberos

- Client accesses server by IP address (no SPN lookup possible)
- Client is not domain-joined (workgroup machine)
- Target is outside the AD forest

- Application explicitly requests NTLM
- Kerberos is unavailable (DNS failure, DC unreachable)

6.3 NTLM Challenge-Response Flow

1. Client sends username to server
2. Server sends random CHALLENGE (8 bytes)
3. Client encrypts challenge with NT password hash
4. Client sends the RESPONSE back
5. Server forwards username + challenge + response to DC
6. DC performs same calculation with stored hash and compares
7. Match = authenticated

6.4 NTLM Versions and Weaknesses

- LM: extremely weak, crackable in seconds, disable everywhere
- NTLMv1: weak, vulnerable to pass-the-hash and relay attacks
- NTLMv2: stronger but still vulnerable to capture and relay
- ! Disable LM and NTLMv1 via GPO. Enforce NTLMv2 minimum. Block NTLM entirely in modern environments where possible.

Chapter 7 – LDAP and Directory Queries

7.1 What is LDAP?

Lightweight Directory Access Protocol – the query language for Active Directory. While Kerberos handles AUTHENTICATION, LDAP handles QUERIES: searching for users, checking group memberships, reading attributes.

7.2 LDAP Ports

- 389 – Standard LDAP (unencrypted – avoid in production)
- 636 – LDAPS – LDAP over SSL/TLS (encrypted – use this always)
- 3268 – Global Catalog LDAP (searches entire forest)
- 3269 – Global Catalog LDAPS (encrypted GC)

7.3 LDAP Operations

- Bind: authenticate to the directory
- Search: query for objects matching a filter
- Add: create a new object
- Modify: change attributes of an existing object
- Delete: remove an object
- Unbind: disconnect

7.4 Distinguished Names (DN)

Every object has a unique DN describing its full path:

CN=John Smith,OU=Sales,OU=London,DC=contoso,DC=com

- CN – Common Name: the object name
- OU – Organisational Unit: the container
- DC – Domain Component: each DNS label

7.5 Key LDAP Attributes

- sAMAccountName: logon name (domain\user format), max 20 chars, unique in domain
- userPrincipalName: UPN (user@domain.com), unique in forest
- objectGUID: globally unique, never changes even if renamed

- objectSID: security identifier, used for access control
- memberOf: list of groups this object belongs to
- pwdLastSet: timestamp of last password change
- lastLogonTimestamp: replicated last logon (up to 14 days old)
- lastLogon: exact last logon but NOT replicated – varies per DC
- userAccountControl: bit flag controlling account state

7.6 LDAP Search Filter Syntax

(objectClass=user) find all users

(sAMAccountName=jsmith) find by logon name

(&(objectClass=user)(department=IT)) AND filter

((department=IT)(department=HR)) OR filter

Chapter 8 – Organisational Units

8.1 OU vs Default Containers

Default Containers (CN=Users, CN=Computers, CN=Builtin)

- Created automatically, CANNOT have GPOs linked, CANNOT have delegation

Organisational Units (OU=)

- Created by admins, CAN have GPOs linked, CAN have delegation applied

* Always move users and computers OUT of default containers INTO OUs.

8.2 OU Design Strategies

- By Geography: London, Paris, New York – good for location-based policies
- By Department: Finance, HR, IT, Sales – good for department-based policies
- By Object Type: Users, Computers, Groups – good for GPO targeting
- Hybrid (most common): London --> IT --> Users/Computers/Groups

8.3 Administrative Delegation

Grant specific permissions to specific accounts over specific OUs without Domain Admin rights. Use Delegation of Control Wizard: right-click OU --> Delegate Control.

- Helpdesk: reset passwords in Users OU only
- London IT: full control over London OU only

8.4 Protecting OUs from Deletion

By default OUs are protected. To delete: View --> Advanced Features --> right-click --> Properties --> Object tab --> untick "Protect from accidental deletion" --> then delete.

Chapter 9 – Users and Accounts

9.1 User Account Types

- Domain User: stored in AD, works on any domain machine, has SID and password hash in NTDS.dit
- Local User: stored on local machine only, not in AD, built-in: Administrator and Guest
- Computer Account: every domain-joined machine has one, ends with \$, password auto-rotated every 30 days
- Service Account: used by services to run under a specific identity, use gMSA for auto-rotating passwords

9.2 userAccountControl Flags

A bitmask controlling account state. Common values:

- 2 = Account disabled
- 16 = Locked out
- 32 = Password not required
- 64 = Cannot change password
- 65536 = Password never expires
- 512 = Normal enabled account
- 514 = Disabled account (512 + 2)

9.3 Password Storage

AD stores NT hashes (MD4 hash of Unicode password) in NTDS.dit. Plaintext is NEVER stored. With Password Hash Sync: a hash of the hash is synced to Entra ID.

9.4 Account Lockout Settings (via GPO)

- Account lockout threshold: how many failures before lockout (recommend: 5–10)
- Account lockout duration: 0 = until admin unlocks, or set minutes
- Reset lockout counter after: minutes to reset the failure count
- * PDC Emulator handles urgent lockout notifications. When a DC locks an account it immediately notifies the PDC Emulator.

Chapter 10 – Groups and Permissions

10.1 Group Types

- Security Groups: assign permissions to resources – use these for access control (99% of the time)
- Distribution Groups: email lists only, cannot assign permissions

10.2 Group Scopes

Domain Local

Members from: any trusted domain/forest. Used for permissions in: THIS domain only. Best for RESOURCE groups (e.g. SalesShare-Modify).

Global

Members from: THIS domain only. Used for permissions in: any trusted domain. Best for USER/COMPUTER groups (e.g. Sales-Team).

Universal

Members from: any forest domain. Used for: any forest domain. Best for forest-wide groups. Stored in Global Catalog.

10.3 AGDLP Best Practice

Accounts --> Global --> Domain Local --> Permissions

Example: jsmith (A) added to Sales-Department Global group (G)

Sales-Department added to SalesShare-Modify Domain Local group (DL)

SalesShare-Modify group granted Modify permission on share (P)

* To add a new sales person: just add them to Sales-Department. They get correct permissions automatically everywhere.

10.4 NTFS vs Share Permissions

- Share permissions: apply when accessing via network (UNC path)
- NTFS permissions: apply at file system level regardless of access method
- When both apply: the MORE RESTRICTIVE permission wins
- Best practice: Share = Full Control to the security group. NTFS = exact permissions needed. All real security is in NTFS.

Chapter 11 – Group Policy

11.1 What is Group Policy?

Allows admins to ENFORCE configuration settings on users and computers automatically. A GPO is a collection of settings pushed to users and computers. Without GPO: configure 500 machines manually. With GPO: one setting applies to all 500 within 90 minutes.

11.2 GPO Structure

- Computer Configuration: applied at STARTUP regardless of who logs in (password policy, firewall, software, startup scripts)
- User Configuration: applied at LOGIN regardless of which computer (mapped drives, wallpaper, logon scripts, folder redirection)

11.3 GPO Processing Order – LSDOU

Applied in this order. LAST one processed WINS conflicts:

- L – Local Group Policy (on machine itself, lowest priority)
- S – Site GPOs
- D – Domain GPOs (Default Domain Policy)
- O – OU GPOs (parent OU first, then child OU – child OU GPO wins)

* Password policy MUST be linked at the DOMAIN level to apply domain-wide. OU-linked password policies only work in Windows Server 2008+ via Fine-Grained Password Policy.

11.4 Default GPOs

- Default Domain Policy: linked to domain root. Contains domain-wide password and lockout policy. Add nothing else here.
- Default Domain Controllers Policy: linked to Domain Controllers OU. Security settings for DCs.

! Never delete Default Domain Policy or Default Domain Controllers Policy. Create separate GPOs for everything else.

11.5 GPO Inheritance Controls

- Block Inheritance: OU blocks GPOs from parent from applying
- Enforced: GPO applies even if child OU has Block Inheritance
- Security Filtering: apply GPO only to specific groups (remove Authenticated Users, add specific group)
- WMI Filter: apply GPO only if WMI query returns true (e.g. only Windows 11 machines)

11.6 GPO Refresh and Key Commands

Refresh: every 90 min for members (random offset up to 30 min), every 5 min for DCs

gpupdate /force force immediate refresh

gpresult /r show applied GPOs for current user and computer

gpresult /h C:\gp.html full HTML report with denied GPOs and reasons

Chapter 12 – AD Replication

12.1 Multi-Master Replication

Unlike traditional databases with a single master, AD uses MULTI-MASTER replication. Changes can be made on ANY writable DC and propagate to ALL others. Exception: FSMO-protected operations.

12.2 Update Sequence Numbers (USNs)

Every change is assigned a monotonically increasing USN. Each DC tracks the highest USN it has received from each replication partner. Replication message: "I have USN 5000 from you – send everything above 5000."

12.3 Intra-site vs Inter-site Replication

- Intra-site (same AD site): automatic, triggered every 15 seconds via change notification
- Inter-site (different sites): scheduled based on site link settings, data is compressed

12.4 The KCC

Knowledge Consistency Checker: automatic process on every DC that calculates the most efficient replication topology. Creates connection objects between DCs. Runs every 15 minutes. You do not need to configure this manually.

12.5 SYSVOL Replication

SYSVOL holds GPO templates, logon scripts, and netlogon scripts. Replicates SEPARATELY from the AD database.

- Windows Server 2012+: DFS-R (preferred, more robust)
- Older: FRS (File Replication Service, legacy, less reliable)

! If SYSVOL breaks, GPOs stop applying and users may not be able to log in. Monitor separately.

12.6 Replication Conflicts

- Last writer wins: change with later timestamp wins
- Equal timestamps: DC with higher GUID wins
- Deletion always wins over modification

Chapter 13 – Sites and Site Links

13.1 What is an AD Site?

A collection of IP subnets with fast, reliable connectivity (typically LAN). Sites represent physical topology. They control: which DC a client authenticates against (prefers local site), how frequently inter-site replication occurs, and DFS referrals.

13.2 Subnets

IP address ranges associated with a site. AD checks client IP against subnets to determine its site. If a client IP does not match any subnet: it defaults to the site of the DC it finds and a warning event is logged.

*** Always define subnets for all network ranges. Missing subnets cause clients to use remote DCs.**

13.3 Site Link Settings

- Cost: relative cost of using this link (lower = more preferred, like routing metrics)
- Replication Interval: how often replication checks for changes (minimum 15 min, default 180 min)
- Schedule: when replication is allowed (restrict to off-peak to save bandwidth)

13.4 Bridgehead Servers

One DC per site handles all inter-site replication traffic (the bridgehead server). KCC selects automatically. You can designate a PREFERRED bridgehead manually for control over which DC handles WAN traffic.

Chapter 14 – FSMO Roles

14.1 Why FSMO Roles?

Some operations are dangerous if two DCs try them simultaneously (duplicate IDs, schema corruption). FSMO roles designate ONE DC as authority for these specific operations. If unavailable, those operations block until the role is transferred or seized.

14.2 Forest-Wide Roles (One per Forest)

Schema Master

Only DC that can modify the AD Schema. Used only when installing Exchange, Lync, or manually extending the schema. Changes are IRREVERSIBLE.

Domain Naming Master

Controls adding/removing domains from the forest. Also manages UPN suffixes.

14.3 Domain-Wide Roles (One per Domain)

RID Master

Allocates pools of Relative IDs (RIDs) to other DCs. Every AD object has SID = Domain SID + RID. RID master prevents duplicate SIDs. Each DC gets 500 RIDs, requests more when running low.

PDC Emulator

Busiest FSMO role. Handles: time synchronisation master for domain, urgent password changes (written here first), account lockout decisions, Group Policy (GPMC connects here by default), legacy NT4 compatibility.

Infrastructure Master

Maintains cross-domain object references. In a single-domain forest, largely irrelevant.

* In multi-domain forests: do NOT put Infrastructure Master on a GC server unless ALL DCs are GCs.

14.4 Transfer vs Seize

- Transfer (graceful): both DCs online, use ADUC / AD Domains and Trusts / AD Schema MMC / PowerShell
- Seize (forceful): use ntdsutil ONLY when original holder is permanently dead and will NEVER come back
- ! After seizing a role, the original DC must NEVER come back online. It will conflict with the new role holder.

Chapter 15 – Trusts

15.1 What is a Trust?

Allows users in one domain/forest to access resources in another without separate accounts. The trusting domain opens access to authenticated users from the trusted domain.

15.2 Trust Direction

- One-way: Domain A trusts Domain B --> users in B can access resources in A. A users cannot access B resources.
- Two-way (bidirectional): both domains trust each other

15.3 Trust Transitivity

- Transitive: if A trusts B and B trusts C, then A trusts C automatically (all intra-forest trusts)
- Non-transitive: limited to the two parties only (External trusts)

15.4 Trust Types

- Parent-Child: automatic, two-way, transitive – created when child domain added
- Tree-Root: automatic, two-way, transitive – created when new tree added to forest
- Forest Trust: manual, configurable direction, transitive within each forest – connects two entire forests
- External Trust: manual, configurable direction, NON-transitive – connects specific domains across forests
- Shortcut Trust: manual, speeds up auth between distant domains in large forest – optimisation only
- Realm Trust: connects AD domain to non-Windows Kerberos realm (Unix, MIT Kerberos)

Chapter 16 – Active Directory Schema

16.1 What is the Schema?

The master definition of every object type and attribute that can exist in AD. Defines object classes (user, computer, group), attributes (name, email, phone), mandatory vs optional attributes, and attribute syntax (string, integer, boolean, date).

16.2 Schema Scope and Location

FOREST-WIDE: one schema for the entire forest, stored on the Schema Master FSMO role holder and replicated to all DCs. All domains in a forest share the same schema.

16.3 Schema Classes

- Structural: actual object types you create (user, computer, group, organizationalUnit)
- Abstract: template classes that structural classes inherit from (cannot create instances directly)
- Auxiliary: add attributes to existing classes – used to extend object types

16.4 Schema Extensions

Schema can be extended to add custom attributes or object types. Done by: Exchange (~800 new attributes), Lync/Skype, System Center, or custom LDIF files.

! Schema changes are IRREVERSIBLE. You can deactivate attributes but cannot truly delete them. Always test in a lab first.

16.5 Viewing the Schema

1. regsvr32 schmmgmt.dll (register the snap-in)
2. mmc.exe --> Add Snap-in --> Active Directory Schema
3. Or use ADSI Edit to view the schema partition directly

Chapter 17 – Global Catalog

17.1 What is the Global Catalog?

A special DC holding: a COMPLETE copy of all objects in its LOCAL domain, and a PARTIAL copy of all objects in all OTHER forest domains (selected attributes only). Allows queries about ANY object in the entire forest without contacting each domain separately.

17.2 Why the GC is Needed

- Universal group membership must be resolved at login – without GC, users cannot log in
- Cross-domain searches fail without GC
- Exchange cannot resolve email addresses without GC
- UPN login (user@domain.com) cannot be resolved without GC if domain differs

17.3 GC Ports

- 3268: LDAP Global Catalog (unencrypted)
- 3269: LDAPS Global Catalog (encrypted)

17.4 GC Placement

- Single-domain forest: all DCs are typically GCs
- Multi-domain forests: at least ONE GC per site required for login to work

! Sites without a GC require WAN access to authenticate. If WAN fails and no local GC: users cannot log in.

Chapter 18 – PKI and Certificates

18.1 What is PKI?

Public Key Infrastructure – a system of digital certificates, CAs, and cryptographic keys enabling encrypted communications and digital identity verification. Underpins HTTPS, LDAPS, email signing, smart card auth.

18.2 Asymmetric Cryptography

- Public Key: shared openly, used to ENCRYPT data or VERIFY signatures
- Private Key: kept secret, used to DECRYPT data or CREATE signatures

What one key encrypts, only the other can decrypt. A message encrypted with your public key can only be decrypted with your private key.

18.3 Digital Certificates

A document binding a public key to an identity. Contains:

- Subject name, subject public key
- Issuer name and digital signature (proves CA issued it)
- Validity period (not before / not after)
- Serial number, key usage / extended key usage

18.4 Certificate Authority (CA) Hierarchy

- Root CA: top-level trust anchor, self-signed, kept OFFLINE in production
- Intermediate/Subordinate CA: signed by Root CA, issues end-entity certificates
- End-entity cert: issued to specific server, user, or device

Trust chain: client trusts Root CA --> Root signed Intermediate --> Intermediate signed server cert --> client trusts server cert.

18.5 Certificate Validation Checks

- Is it signed by a trusted CA? (chain of trust check)
- Is it within validity period?
- Is it revoked? (CRL – Certificate Revocation List, or OCSP – Online Certificate Status Protocol)
- Does subject name match what we connected to?
- Is it appropriate for this use? (key usage check)

Chapter 19 – AD CS – Certificate Services

19.1 What is AD CS?

Windows Server role that lets you run your own Certificate Authority integrated with Active Directory. Issue certificates to internal servers (LDAPS, HTTPS), users (smart card), and computers (802.1x). All domain members automatically trust your internal CA.

19.2 Enterprise CA vs Standalone CA

Enterprise CA

- AD-integrated, uses certificate templates, supports auto-enrollment via GPO
- Requires Domain Admin, use this in domain environments always

Standalone CA

- No AD integration, manual requests only, used for OFFLINE ROOT CAs

19.3 Certificate Templates

Define settings for certificates the CA can issue: key size/algorithm, validity period, key usage, who can request, whether auto-enrollment is allowed.

Common templates: Domain Controller, User, Computer, Web Server, Smart Card Logon

19.4 Auto-Enrollment

Via Group Policy, domain computers AUTOMATICALLY request, renew, and remove certificates. DCs auto-get LDAPS certs. Computers auto-get 802.1x WiFi certs. Users auto-get smart card certs. Zero manual intervention.

Chapter 20 – Security and Hardening

20.1 Tiered Administration Model

Three-tier model limiting blast radius of compromised credentials:

- Tier 0 – Control Plane: Domain Controllers, AD, ADFS, PKI. Tier 0 admins NEVER log into Tier 1/2 systems.
- Tier 1 – Server Management: Windows Servers, applications, services.
- Tier 2 – Workstation Management: end-user workstations, helpdesk.

* Key rule: credentials from a higher tier NEVER touch a lower tier system. Workstation compromise cannot yield DC admin credentials.

20.2 Privileged Account Best Practices

- Rename built-in Administrator account (attackers always try "Administrator" first)
- Disable built-in Guest account
- Separate admin accounts: jsmith for daily work, jsmith-adm for admin tasks
- Domain Admins group: minimum membership, audit regularly
- Enterprise Admins / Schema Admins: should be EMPTY except when actively needed

20.3 Password Policy Best Practices

- Minimum 14 characters (longer is better than complex)
- History: remember last 24 passwords
- Lockout: 5-10 failures, auto-unlock after 30 minutes
- Fine-grained password policy: stricter rules for privileged accounts

20.4 Key Security Settings to Configure

- ms-DS-MachineAccountQuota = 0 (default 10 allows any user to join 10 machines)
- Disable SMBv1 (WannaCry/EternalBlue vector)
- Enable SMB signing (prevents SMB relay attacks)
- Disable LLMNR and NBT-NS (prevent poisoning attacks)
- Use LDAPS (port 636) not LDAP (port 389)
- Enable AD Recycle Bin (recover accidentally deleted objects)
- Protected Users security group: add privileged users to prevent credential theft

Chapter 21 – Auditing and Event IDs

21.1 Enabling Audit Policies

Windows does NOT log security events by default. Enable via:

- Group Policy: Computer Config --> Security Settings --> Advanced Audit Policy Configuration (preferred – more granular)
- Command line: auditpol /set /subcategory:"Logon" /success:enable /failure:enable

21.2 Authentication Events

- 4624 – Account successfully logged on
 - o Type 2: interactive (keyboard) | Type 3: network | Type 4: batch
 - o Type 5: service | Type 7: unlock | Type 10: RDP | Type 11: cached
- 4625 – Account failed to log on
 - o SubStatus 0xC000006A: correct username, wrong password
 - o SubStatus 0xC0000064: username does not exist
 - o SubStatus 0xC0000234: account locked out
 - o SubStatus 0xC0000072: account disabled
 - o SubStatus 0xC000006F: login outside allowed hours
- 4740 – Account locked out
- 4767 – Account unlocked

21.3 Account Management Events

- 4720 – User account created
- 4722 / 4725 – User account enabled / disabled
- 4724 – Admin reset user password
- 4726 – User account deleted
- 4738 – User account changed (attribute modified)
- 4781 – Account name changed

21.4 Group Membership Events – CRITICAL

- 4728 – Member added to security-enabled GLOBAL group
 - 4729 – Member removed from global group
 - 4732 – Member added to security-enabled LOCAL group
 - 4756 – Member added to security-enabled UNIVERSAL group
- ! ALERT ON any addition to Domain Admins, Enterprise Admins, Schema Admins. These are critical security events.

21.5 Kerberos and Directory Events

- 4768 – Kerberos TGT requested (AS-REQ/AS-REP)
- 4769 – Kerberos service ticket requested (TGS-REQ/TGS-REP)
- 4771 – Kerberos pre-authentication failed
- 4662 – Operation performed on an object (detect DCSync)
- 5136 – Directory service object modified
- 5137 – Directory service object created
- 5141 – Directory service object deleted

Chapter 22 – AD Attack Techniques

22.1 Password Spraying

Technique

Try ONE common password against MANY accounts. Stays under lockout threshold (e.g. 1 attempt per account, 500 accounts = 500 attempts, 0 lockouts). Common passwords: Company123!, Season+Year!, CompanyName1.

Detection: Event ID 4625

Many 4625 failures across DIFFERENT accounts from ONE source IP in short time. Normal brute force = many 4625 against ONE account.

Defence

- MFA on all accounts (makes spraying pointless)
- Banned password lists (Entra ID has this built in)
- Strong password policy – longer passphrases

22.2 Kerberoasting

Technique

Any authenticated user can request a service ticket (TGS-REP) for any account with an SPN. The ticket is encrypted with the service account password hash. Attacker takes the ticket offline and cracks it. No special privileges needed – this is NORMAL Kerberos behaviour.

Detection

Event ID 4769 – high volume for unusual services from one account. RC4 encryption type in 4769 events (weaker, faster to crack).

Defence

- Service accounts with LONG RANDOM passwords (25+ chars)
- Group Managed Service Accounts (gMSA) – 120 char passwords, auto-rotated
- AES encryption for Kerberos instead of RC4

22.3 AS-REP Roasting

Technique

Targets accounts with "Do not require Kerberos preauthentication" enabled. Without pre-auth, the KDC issues an AS-REP containing data encrypted with the USER password hash – without the attacker proving they know the password first.

Defence

- Ensure pre-authentication is enabled for ALL accounts (it is the default – never disable it)
- Audit for accounts with DONT_REQUIRE_PREAUTH flag set

22.4 DCSync

Technique

Attacker with replication privileges uses AD replication protocol to request ALL password hashes directly from a DC. Pretends to be a DC doing normal replication. No malware needed on DC. Extracts Domain Admin and KRBTGT hashes.

Detection

Event ID 4662 with replication GUIDs from a NON-DC account. Defender for Identity detects DCSync natively.

Defence

- Restrict "Replicating Directory Changes" to DC computer accounts only
- Monitor 4662 events for replication from non-DC accounts

22.5 Pass-the-Hash (PtH)

Technique

NTLM authentication accepts password HASH as proof of identity. Attacker extracts NTLM hash from memory (Mimikatz etc.) and authenticates AS that user without knowing the plaintext password.

Defence

- Credential Guard: protects LSASS memory from hash extraction
- LAPS: unique local admin passwords per machine (prevents lateral movement)
- Tiered admin model: admin credentials never used on workstations

22.6 Golden Ticket

Technique

KRBTGT hash encrypts ALL TGTs. If attacker obtains this hash (via DCSync or DC compromise), they can FORGE TGTs for any user with any group membership and any ticket lifetime. Works even after real user password is changed.

Defence

- Rotate KRBTGT password TWICE after any suspected compromise (KDC caches old key)
- Protect DCs – KRBTGT hash only comes from DC compromise
- Monitor for Kerberos tickets with unusual lifetimes or impossible group memberships

22.7 LLMNR/NBT-NS Poisoning

Technique

When DNS fails, Windows uses broadcast protocols (LLMNR and NBT-NS). Attacker on same network responds to broadcasts claiming to be the target host, captures NTLM hashes when victim authenticates.

Defence

- Disable LLMNR via GPO: Computer Config --> Admin Templates --> Network --> DNS Client --> Turn off multicast name resolution
- Disable NBT-NS: network adapter --> IPv4 --> Advanced --> WINS --> Disable NetBIOS over TCP/IP

Chapter 23 – PowerShell for AD

23.1 Getting Started

- Import-Module ActiveDirectory load the module (auto on DCs)
- Get-Command -Module ActiveDirectory list all ~150+ cmdlets
- Get-Help Get-ADUser -Examples see examples for any cmdlet

23.2 User Queries

Get-ADUser -Filter * all users

Get-ADUser -Identity jsmith specific user

Get-ADUser -Filter {Name -like "*smith*"} search by name

Get-ADUser -Identity jsmith -Properties * all attributes

Get-ADUser -Filter * -SearchBase "OU=Sales,DC=..." users in OU

Get-ADUser -Filter {Enabled -eq \$false} disabled accounts

Get-ADUser -Filter {PasswordNeverExpires -eq \$true} no expiry accounts

23.3 Creating and Modifying Users

New-ADUser -Name "Full Name" -SamAccountName logon -Path "OU=..." -Enabled \$true -AccountPassword (ConvertTo-SecureString "Pass" -AsPlainText -Force) -ChangePasswordAtLogon \$true

Set-ADUser -Identity jsmith -Department "IT" -Title "Analyst"

Disable-ADAccount -Identity jsmith

Enable-ADAccount -Identity jsmith

Unlock-ADAccount -Identity jsmith

Set-ADAccountPassword -Identity jsmith -NewPassword (...) -Reset

Remove-ADUser -Identity jsmith -Confirm:\$false

Move-ADObject -Identity (Get-ADUser jsmith).DistinguishedName -TargetPath "OU=..."

23.4 Group Management

Get-ADGroup -Filter * | Select Name, GroupScope, GroupCategory

Get-ADGroupMember -Identity "Domain Admins" | Select Name

Add-ADGroupMember -Identity "Sales-Team" -Members jsmith,mjones

Remove-ADGroupMember -Identity "Sales-Team" -Members jsmith -Confirm:\$false

Get-ADUser jsmith -Properties MemberOf | Select -Expand MemberOf

23.5 Security Audit Scripts

Stale Accounts (not logged in 90+ days)

\$cutoff = (Get-Date).AddDays(-90)

Get-ADUser -Filter {LastLogonTimestamp -lt \$cutoff -and Enabled -eq \$true} -Properties LastLogonTimestamp | Select Name, @{N="LastLogon";E={[DateTime]::FromFileTime(\$_.LastLogonTimestamp)}}

Password Never Expires

Get-ADUser -Filter {PasswordNeverExpires -eq \$true -and Enabled -eq \$true} | Select Name, SamAccountName

Domain Admin Audit

Get-ADGroupMember -Identity "Domain Admins" -Recursive | Select Name, SamAccountName

Export All Users for Access Review

Get-ADUser -Filter * -Properties Department, LastLogonDate | Export-Csv "C:\UserAudit.csv" -NoTypeInformation

Security Event Log Queries

Get-WinEvent -FilterHashtable @{'LogName'="Security"; 'Id'=4625} -MaxEvents 10 | Format-List TimeCreated, Message

Get-WinEvent -FilterHashtable @{'LogName'="Security"; 'Id'=4728} -MaxEvents 10

Chapter 24 – Troubleshooting Active Directory

24.1 The Troubleshooting Mindset

AD problems almost always come from: DNS failure (most common), network/firewall issue, time sync problem, or replication failure. Work bottom-up: network --> DNS --> time --> services --> AD behaviour.

24.2 Essential Commands

DC Health

`dcdiag /v` comprehensive DC health check

`dcdiag /test:replications` replication test

`dcdiag /test:dns` DNS test

Replication

`repadmin /replsummary` quick summary (0 failures = healthy)

`repadmin /showrepl` detailed per-partner status

`repadmin /syncall /A /e /P` force immediate replication

Domain and DC Location

`netdom query fsmo` who holds each FSMO role

`nltest /dsgetdc:domain.com` find a DC

`nltest /sc_verify:domain.com` verify secure channel

DNS

`nslookup domain.com` basic resolution

`nslookup -type=srv _ldap._tcp...` SRV records

`ipconfig /flushdns` clear DNS cache

Time

`w32tm /query /status` time sync status

`w32tm /resync /force` force resync

Group Policy

`gpupdate /force` force immediate refresh

`gpresult /r` show applied GPOs

`gpresult /h C:\gp.html` full HTML report

24.3 Common Problems and Solutions

"Domain does not exist or could not be contacted"

Cause: DNS misconfigured, DC offline, firewall blocking. Fix: check DNS points to working DC, ping the DC, run `nltest /dsgetdc`.

"Trust relationship between workstation and domain failed"

Cause: machine account password out of sync (after long suspension or old snapshot restore). Fix: `Test-ComputerSecureChannel -Repair -Credential (Get-Credential)`

Users cannot log in

1. Can they log in on a different machine? No = account issue. Yes = machine issue.
2. Is the account locked out? Check Event ID 4740 on PDC Emulator.
3. Is DNS working? `nslookup domainname` from affected machine.
4. Can the machine reach a DC? `ping dc01.domain.com`
5. Is time synchronised? `w32tm /query /status`

Group Policy not applying

1. GPO linked to correct OU? Check GPMC.
2. Security Filtering excluding the object?
3. `gpresult /h report.html` – read Denied GPOs section.
4. Is SYSVOL replication healthy? Check Event Viewer --> DFS Replication log.

"Access denied" despite correct group membership

Cause: Kerberos TGT cached before group was added. Group not in the ticket. Fix: user must fully LOG OFF and log back in (not lock/unlock) to get fresh TGT with updated group membership.

Chapter 25 – Hybrid Identity – Entra ID

25.1 What is Hybrid Identity?

Most organisations run BOTH on-premises AD and cloud services. Hybrid identity bridges them: single set of credentials for both, on-premises users access Microsoft 365, cloud policies (Conditional Access) apply to on-premises users.

25.2 Microsoft Entra ID vs AD DS

- Entra ID uses OAuth 2.0 and OpenID Connect – NOT Kerberos
- Entra ID uses REST APIs – NOT LDAP
- No OUs – flat structure with Groups and Administrative Units
- No Group Policy – uses Intune MDM/MAM policies instead
- Conditional Access instead of network perimeter security

! Entra ID is NOT "AD in the cloud." They are fundamentally different systems with different protocols and features.

25.3 Microsoft Entra Connect

Software installed on-premises (NOT on a DC in production) that synchronises identities from AD DS to Entra ID. Runs every 30 minutes by default.

Synchronisation Methods

- Password Hash Sync (PHS): syncs hash of the hash to Entra ID. Simplest and most reliable.
- Pass-Through Authentication (PTA): cloud auth requests passed to on-premises agent. Password never leaves on-premises.
- Federation (AD FS): separate servers handle authentication. Most complex.

25.4 Conditional Access

Entra ID policy engine. Context-aware access decisions based on:

- User/group identity
- Location (IP address, country)
- Device compliance state (Intune)
- Application being accessed
- Sign-in risk score (Entra ID Protection ML scoring)

Example policy: IF user is Finance AND location is outside EU AND device is not compliant THEN require MFA.

*** Always test Conditional Access in REPORT-ONLY mode first. Misconfigured CA policies can lock out all admins from the tenant.**

25.5 Break-Glass Accounts

Emergency Global Admin accounts excluded from ALL Conditional Access policies. Required because a misconfigured CA policy can lock out every admin with no way back in.

- Global Admin role, excluded from all CA policies
- Password-only (no MFA requirement in case phone breaks)
- Very long random password stored offline (in a safe)
- Two accounts in case one has a problem
- Sign-in monitored – any use generates an immediate alert

End of Notes – 25 Chapters Complete

Active Directory General Theory | IAM – IT Infrastructure – Cloud Security – SOC